EWB COURSES

AI-POWERED CYBERSECURITY

Assessment 01: Security Foundations

STUDENT NAME	**T. Rohitha**
COLLEGE	**Panimalar Engineering College**
DEPARTMENT	**Computer Science and Engineering**
BATCH / GROUP	**2024-2028**
SUBMISSION DATE	**30-10-2026**

TASK A — SECURE A STUDENT ACCOUNT

A1–A2. Risks, assets, CIA impact, controls and limitations

Risk / scenario	Asset at risk	Possible CIA impact	Practical control and why it helps	Limitation
Weak or reused password	Email and learning-portal credentials; linked services	C: high;I:high; A: medium.One exposed password may allow accessto more thanone account.	Use a unique,long password foreach account; use a reputablepassword manager andenable MFA. This reducesguessing and password-reuserisk.	MFA can still be phished or bypassed; a password manager itself must be protected.
Unexpected MFA prompt approved	Account authentication and personal/academic data	C: high;I:high; A: medium.An attackermay enter the accountor change settings.	Deny unexpected prompts. Approve only a sign-in the student personally initiated; report repeated prompts and review sessions.	A user may still be pressured or confused by repeated prompts; MFA methods differ in phishing resistance.

Delayed device updates	Laptop, browser, files and saved credentials	C: high; I: high; A: high. Known vulnerabilities may be exploited, data altered, or access disrupted.	Install operating-system, browser and security updates promptly; enable automatic updates where suitable.	Updates cannot eliminate every vulnerability and may occasionally require restart or compatibility checks.
Only project copy on one laptop	Project files and coursework	A: high; I: medium; C: medium. Device loss, failure or malware could make the only copy unavailable or corrupt it.	Keep a second, versioned backup in a trusted cloud service or external drive; test that files can be restored.	A backup may also be lost, infected or inaccessible if it is not protected and checked.
Friend uses laptop while Mira is signed in	Email, learning portal, private files and active sessions	C: high; I: high; A: medium. Another person could read, change or delete content or act as Mira.	Lock the screen when away; use separate OS accounts; sign out of sensitive services and do not share the signed-in profile.	A user may forget to lock or sign out; separate accounts still need suitable permissions and device security.

A3. Three prioritised actions

Protect sign-in first — Change the reused password to a unique, long password, enable MFA, and never share passwords, OTPs or recovery codes. This comes first because account takeover can expose multiple services quickly.

Verify before acting — Open the college portal through a saved bookmark or independently typed official address. Do not sign in through unexpected email or SMS links. This reduces phishing risk before credentials are entered.

Protect the device and files — Update the operating system and browser, lock the laptop, use a separate account for the friend, sign out of shared sessions, and maintain tested backups. These actions reduce device misuse and data-loss risk.

A4. Authentication versus authorisation

Authentication verifies who a user is. For example, Mira enters her username and password and completes an MFA check to sign in to the college learning portal.

Authorisation determines what an authenticated user is permitted to do. Mira may be allowed to view and submit her own assignments, while a lecturer may be allowed to grade submissions. In short, authentication asks “Who are you?” and authorisation asks “What are you allowed to do?”.

TASK B — ANALYSE A SUSPICIOUS MESSAGE

The supplied message uses a scholarship theme to create urgency and requests credentials, an OTP and an identity-card photo. These are warning signs that require independent verification. The report does not claim that a real sender or website exists; the addresses are fictional .example training addresses.

B1. Five specific warning signs

Quoted evidence	Why it needs scrutiny
“Reply-To: help@personal-awards.example”	The reply address differsfrom the displayed sender domain. A mismatch is not proof offraud, but it should be checked independently.
“FINAL WARNING - scholarship expires in 20 minutes”	Strong urgency pressures the recipient to act before checking the message with the college.
“enter your college password and OTP”	A scholarship message should not require the student to disclose a password or one-time passcode. These secrets could enable account access.
“Do not contact the college office”	The message discourages independent verification, which is a common manipulation tactic.
“Reply with a photo of your identity card”	It requests sensitive identity information through an unverified message, creating a risk of identity misuse.

The link uses a domain different from the stated normal college domain, campus.example. That is another reason to verify the message rather than opening the link. The displayed name “Scholarship Desk” is not proof of sender identity.

B2. Safe verification procedure

Do not interact with the message — Do not click its link, reply, or provide a password, OTP, recoverycodeoridentitydocument.

Use an independent route — Open the known official college website or student portal using a saved bookmark or a separately verified address. Do not use the link supplied in the suspicious message.

Contact the right office — Use contact details obtained independently from the official website or student portal to contact the scholarship office or college IT team. Ask whether the offer and message are genuine.

Report and preserve — Report the message through the college's official reporting process. Preserve the message and relevant details if the security team needs them.

Why HTTPS and a familiar display name are insufficient: HTTPS encrypts the connection between a browser and a website; it does not prove that the site belongs to the college or that an email is genuine. A

sender can choose or imitate a familiar display name. Check the full sender and reply-to addresses, the domain, the message content, and independent confirmation.

B3. If a password and OTP were already entered

1. **Contain immediately** — Using a trusted device, go directly to the official portal and change the exposed password.

Change any other account password that reused it.

2. **Secure active access** — Sign out of other sessions, revoke unfamiliar devices or application access, and review recovery email addresses, phone numbers and MFA settings.
3. **Report through official channels** — Contact the college IT/security team promptly and explain that credentials may have been exposed. Never send the actual password or OTP to support staff.
4. **Check for misuse and follow up** — Review recent sign-ins, account changes and unfamiliar activity. Preserve the suspicious message and timestamps, follow the security team's instructions, and monitor for further alerts.

B4. What cannot be established from the message alone

The message alone cannot establish whether the sender is genuinely associated with the college or whether the scholarship offer is real. Helpful additional evidence would include full email headers and authentication results, plus confirmation from the college scholarship office using an independently obtained official contact. The supplied text alone is not enough to prove the identity or intent of a sender.

TASK C — TRIAGE A SIGN-IN ALERT

All timestamps below are IST on 18 October 2026. The supplied IP addresses are reserved documentation examples. The usual classroom egress IP is stated to be 192.0.2.10. A different IP address by itself does not prove an attack or identify a person.

C1. Four-point timeline

Point / time	Observed evidence	Interpretation (not proven fact)
1. Baseline— 09:00–09:01	student07 had a Password event from 192.0.2.10 marked Success at 09:00, followed by an MFA event marked Approved at 09:01.	This is consistent with normal sign-in activity and provides a baseline. The record should still be interpreted according to the system's event definitions.
2. Unfamiliar source — 10:14–10:16	Three Password events from 198.51.100.23: Failed at 10:14, Failed at 10:15, and Success at 10:16.	Repeated attempts followed by a success are concerning and need investigation. The IP address does not identify the person behind the activity.
3. MFA activity — 10:17–10:18	An MFA event was Denied at 10:17 and Approved at 10:18. The student says they did not sign in after 09:05 and approved a prompt around 10:18 to stop repeated requests.	The statement and log raise concern that an unexpected prompt may have been approved. The relationship between the approval and any later session must be verified.
4. Possible session creation — 10:20	A Session event from 198.51.100.23 was recorded as Created.	This may indicate a session was established after the unusual authentication activity. IT should verify the session's authentication context and whether it remains active.

C2. Likely explanation and alternative explanation

Likely explanation: Someone may have obtained or guessed the student's password and attempted to access the account. The successful password event at 10:16, the MFA approval at 10:18, and the session-creation event at 10:20 could be consistent with unauthorised access. The available records do not conclusively prove this explanation.

Alternative explanation: The events could be associated with a legitimate but unrecognised session, a device or application retrying authentication, or an issue in how events were logged or grouped. The different IP address alone does not prove an attack.

Two additional checks:

Inspect authentication and session logs — Confirm the meaning and sequence of each event, whether the 10:18 MFA approval is linked to the 10:20 session, and whether the session is still active.

Verify device and account activity — Ask the student through a trusted channel about their devices and recent activity; check device details, application access, account changes and nearby sign-in records.

C3. Three prioritised actions for the authorised IT team

1. **Contain the possible compromise** — Revoke suspicious sessions and refresh tokens, temporarily restrict access if necessary, and help the student change the password through the official service. Reset MFA securely and check recovery details.
2. **Preserve and investigate evidence** — Preserve authentication logs, session records, timestamps, source-IP information and the student's statement. Record actions taken and investigate the sequence before evidence is lost.
3. **Recover and monitor** — Review other sessions, registered devices, connected applications and account changes.

Restore access securely, notify the appropriate security personnel and monitor for further suspicious attempts.

C4. Incident summary

On 18 October 2026, student07 recorded a successful password event and an approved MFA event from the usual classroom IP at 09:00–09:01. From 10:14, password attempts from a different documentation IP included failures followed by a success; an MFA denial and approval followed, and a session was recorded as created at 10:20. The student denies signing in after 09:05 but reports approving an unexpected prompt. Possible account compromise requires investigation; the logs do not identify an attacker or prove unauthorised access. IT should revoke suspicious sessions, secure the account and preserve evidence.

TASK D — REVIEW AN AI SECURITY ANSWER

The fictional AI output contains unsafe advice and conclusions that go beyond the supplied evidence. A reliable review should distinguish observed events from assumptions, preserve evidence, protect secrets and state uncertainty.

D1. Five unsafe or unsupported claims and corrections

Unsafe / unsupported claim	Correction and reason
“The email is safe because it uses HTTPS.”	HTTPS protects data in transit between a browser and a website, but it does not prove that a website or email is legitimate. Phishing sites can also use HTTPS. Verify the domain and message through an independently obtained official route.
“The person using 198.51.100.23 stole the password.”	The logs do not establish a person's identity or prove how a password was obtained. An IP address is contextual evidence, not proof of identity or intent. Examine device details, event sequence and surrounding activity.
“MFA prevents every account compromise.”	MFA improves security but cannot prevent every attack. Phishing, social engineering, MFA-fatigue attacks or stolen sessions may still cause compromise. Use phishing-resistant MFA where available and review unfamiliar prompts.

“Delete the suspicious logs.”	Do not delete relevant security evidence. Preserve logs, timestamps, device information, authentication results and alerts, and share them securely with authorised IT/security personnel.
“Send the student's password to support so they can test it.”	Never send passwords, OTPs or recovery codes to support staff. If compromise is suspected, change the password through the official service from a trusted device, revoke unfamiliar sessions and contact support through verified official channels.

D2. Improved AI prompt

Act as a cautious cybersecurity educator. Analyse only the synthetic evidence provided in the assessment. Identify unsafe, incorrect or unsupported claims and actions. For each issue, briefly quote the relevant claim, explain the risk in simple language, and provide a safer correction supported by trustworthy references where possible. Clearly separate directly observed facts from assumptions and conclusions. Do not identify an attacker or claim that a password was stolen unless the evidence supports it. Explain the limitations of IP addresses, sign-in logs, HTTPS and multi-factor authentication. Recommend preserving relevant security logs rather than deleting them. Never request or reveal passwords, OTPs, recovery codes or other confidential information. If account compromise is suspected, prioritise containment and verification. State explicitly what cannot be concluded from the available evidence.

D3. Corrected security advice

Protect your student account with a unique, long password that you do not reuse on other services. Enable multi-factor authentication using the strongest option supported by the institution, and never disclose passwords, OTPs or recovery codes to anyone. Treat unexpected messages that demand urgent action, request confidential information, or contain unfamiliar links or attachments as suspicious. Do not rely on a sender's display name or on HTTPS alone to decide whether a website is genuine. Open the college portal using a saved bookmark or a manually typed official address, and verify unusual requests through independently obtained contact details. Keep your operating system, browser and security software updated. If credentials may have been exposed, change the password from a trusted device, revoke unfamiliar sessions, review recovery settings, and contact the institution's official IT/security team. Preserve relevant evidence and monitor the account for unauthorised activity.

D4. AI-use declaration

I used an AI assistant to help organise this report, explain cybersecurity concepts in plain language, and draft possible controls and response steps. I reviewed the material for clarity and relevance. AI-generated content is not treated as unquestionable evidence; facts and scenario-specific conclusions must be checked against the original assessment and reliable references. I take responsibility for the final submitted work and will revise any illustrative examples to match the supplied case details.

D5. Evidence/reference notes

Evidence Note 1 — Synthetic sign-in evidence: The assessment provides the synthetic IP address 198.51.100.23 and fictional sign-in records. These details do not establish the identity of an attacker or prove

that a password was stolen. The IP addresses are documentation examples. The logs should be preserved and examined alongside other available evidence.

Evidence Note 2 — Password protection and incident response: Passwords, OTPs and recovery codes must remain confidential. If compromise is suspected, the account owner should secure the account, review active sessions and contact the institution's authorised security team. Relevant logs and suspicious messages should be preserved rather than delet